
홈페이지 취약점 점검 결과보고서

(기업명 : 트위그팜)

2023. 10. 16

주식회사 한국기업보안

안 내 사 항

- 본 홈페이지 취약점 점검 보고서는 웹 사이트에서 발생할 수 있는 SQL 인젝션, 크로스 사이트 스크립트(XSS) 등의 주요 웹 취약점 점검과 홈페이지에 대한 주요 취약점을 점검한 결과를 분석한 보고서입니다.
- 본 결과 보고서는 홈페이지에 대한 주요 취약점을 점검한 결과로 점검과정에서 발견하지 못한 취약점이 존재할 수 있습니다.
- 본 결과 보고서에 언급된 주요 취약점에 대해서는 우선 조치가 필요하며, 발견되지 않은 취약점도 지속적인 점검 등 관리를 해주시기 바랍니다.
- 본 결과 보고서는 참고자료이므로, 외부 증빙자료로 활용될 수 없습니다.

[목 차]

I. 점검 개요	1
II. 홈페이지 취약점 점검 결과 (요약)	2
III. 상세 취약점 점검 결과.....	3
IV. 기타	4

1. 목적

- 홈페이지는 기업에 존재하는 내부정보(DataBase)가 외부망과 연결되어 있는 필수불가결적인 보안상 Hole로 작용할 수 있음
- 홈페이지의 개발영역에서 취약점이 존재하여 피해가 발생한다면 기업의 이미지가 훼손을 포함하여 법적, 금전적 피해가 발생할 가능성이 있음
- 홈페이지가 공격에 의해 악성코드 유포지 및 경유지, 개인정보 유출 등 침해 사고가 발생할 수 있으므로 취약점 점검을 통한 기술지원

2. 점검 대상 및 내용

- 신청업체 : 트위그팜
- 점검 URL : works.lettr.ai
- 신청일자 : 2023. 10. 12, 점검일자 : 2023. 10. 13
- 점검자 : 박영식 컨설턴트

3. 점검방법 및 내용

- 점검방법 : 홈페이지에 대하여 원격으로 점검을 실시하며, 수동진단과 자동화 도구를 병행하여 점검
- 점검항목 : 과학기술정보통신부에서 공고한 주요 홈페이지 취약점인 28개 항목에 대해 취약점 점검 실시 (※SQL 인젝션, 크로스사이트스크립트 등 28개)
- 점검내용 : 관리자 권한 획득, 허용되지 않은 데이터 접근, 위조, 변조 및 개인정보 유출 가능성 등에 대한 점검을 실시하며, 시스템 가용성 문제와 연관된 주요 취약점을 필수로 점검

※ 취약점 점검에 있어 민감한 사항의 열람, 삭제, 수정 실시하지 않음

II 홈페이지 취약점 점검 결과 (요약)

○ 총 28개 취약점 항목 중 **취약 0건**

구 분	취약점 점검 항목	점검 결과
시스템 장애	운영체제 명령 실행	미발견
	파일 업로드	미발견
	SQL 인젝션	미발견
	LDAP 인젝션	미발견
정보 노출	XPath 인젝션	미발견
	정보노출	미발견
	파일 다운로드	미발견
	데이터 평문전송	미발견
악성코드 감염 및 전파	관리자 페이지 노출	미발견
	위치 공개	미발견
	SSI 인젝션	미발견
	경로추적	미발견
사용자 계정 탈취	악성콘텐츠	미발견
	크로스 사이트 스크립트(XSS)	미발견
	약한 문자열 강도	미발견
	취약한 패스워드 복구	미발견
권한 탈취	불충분한 인증	미발견
	불충분한 인가	미발견
	불충분한 세션 만료	미발견
	크로스 사이트 리퀘스트 변조	미발견
시스템 파일 노출	쿠키변조	미발견
	포맷스트링	미발견
	버퍼오버플로우	미발견
	프로세스 검증 누락	미발견
시스템 과부하	세션예측	미발견
	세션고정	미발견
	디렉터리 인덱싱	미발견
	자동화 공격	미발견

※ 상기 양호항목은 이후 다른 시점에 취약항목으로 발견될 수 있음

Ⅲ 상세 취약점 점검 결과

1. 홈페이지의 구성 및 현황

웹서버	사용언어	CMS / Builder
-	JAVA	-

2. 취약점 점검 결과

발견된 취약점 없음.

IV 기타

1. 홈페이지 보안 관련 참고 가이드

1-1) 주요정보통신기반시설 기술적 취약점 분석 평가 상세 가이드

1-2) 홈페이지 개인정보 노출방지 안내서

1-3) 공개SW를 활용한 소프트웨어 개발보안 검증가이드

1-4) JAVA 시큐어코딩 가이드

1-5) C 시큐어코딩 가이드

1-6) 소프트웨어 개발 보안 가이드

1-7) 소프트웨어 보안약점 진단가이드

2. 정보보호 및 개인정보보호 관련 법률

2-1) 정보통신망 이용촉진 및 정보보호 등에 관한 법률

2-2) 개인정보보호법

3. 주요 취약점 점검 항목 설명(28개)

- 과학기술정보통신부에서 고시한 주요정보통신기반시설 점검 기준을 준용하여 웹 부분 28개 항목에 대해 취약점 점검 실시

점검 항목	설명
SQL인젝션	◆SQL문으로 해석될 수 있는 입력을 시도하여 데이터베이스에 접근할 수 있는 취약점 ◆비정상적인 요청에 대한 유효성 점검 → DB 정보 획득 및 저장된 데이터를 임의로 열람 및 조작 → DB의 시스템 명령을 이용하여 시스템 실행
운영체제 명령 실행	◆웹사이트의 인터페이스를 통해 웹 서버를 운영하는 운영체제 명령을 실행하는 취약점
XPath 인젝션	◆조작된 XPath(XML Path Language) 쿼리를 보냄으로써 비정상적인 데이터를 쿼리를 이용해 가져 올 수 있는 취약점
포맷스트링	◆스트링을 처리하는 부분에서 메모리 공간에 접근할 수 있는 문제를 이용하는 취약점
크로스사이트스크립트	◆웹 어플리케이션을 사용해서 다른 최종 사용자의 클라이언트에서 임의의 스크립트가 실행되는 취약점 ◆게시판 등에서 글쓰기 기능을 통한 스크립트 실행 여부 점검 ◆스크립트를 통한 데이터 수정, 삭제 가능 여부 점검
파일 업로드	◆파일을 업로드 할 수 있는 기능을 이용하여 시스템 명령어를 실행할 수 있는 웹 프로그램을 업로드 할 수 있는 취약점 ◆악성파일(웹쉘) 업로드 및 실행 여부 점검 → 서버에서 실행 가능한 확장자(asp, jsp, php)를 가진 파일의 업로드 가능 여부 확인(확장자필터링 우회 여부) → 업로드 파일의 실행 가능 여부 확인
파일 다운로드	◆파일 다운로드 스크립트를 이용하여 첨부된 주요 파일을 다운로드 할 수 있는 취약점 ◆파일 다운로드 알고리즘 보안성 점검 → 다운로드 스크립트의 파라미터를 변경하여 주요 파일 다운로드 시도
버퍼 오버플로우	◆메모리나 버퍼의 블록 크기보다 더 많은 데이터를 넣음으로써 결함을 발생시키는 취약점
LDAP 인젝션	◆LDAP(Lightweight Directory Access Protocol) 쿼리를 주입함으로써 개인정보 등의 내용이 유출될 수 있는 문제를 이용하는 취약점
악성 콘텐츠	◆웹 어플리케이션에 정상적인 콘텐츠 대신 악성 콘텐츠를 주입하여 사용자에게 악의적인 영향을 미치는 취약점
프로세스 검증 누락	◆공격자가 응용의 계획된 플로우 통제를 우회하는 것을 허가하는 취약점
약한 문자열 강도	◆사용자의 이름이나 패스워드, 신용카드 정보나 암호화 키 등을 자동으로 대입하여 여러 시행착오 후에 맞는 값이 발견되는 취약점
불충분한 세션 만료	◆세션의 만료 기간을 정하지 않거나, 만료일자를 너무 길게 설정하여 공격자가 만료되지 않은 세션 활용이 가능하게 되는 취약점
데이터 평문 전송	◆서버와 클라이언트간 통신 시 암호화하여 전송을 하지 않아 중요 정보 등이 평문으로 전송되는 취약점
쿠키 변조	◆적절히 보호되지 않은 쿠키를 사용하여 쿠키 인젝션 등과 같은 쿠키 값 변조를 통한 다른 사용자의 위장 및 권한 상승 등이 가능한 취약점
크로스 사이트 리퀘스트 변조(CSRF)	◆CSRF 공격은 로그인 한 사용자 브라우저로 하여금 사용자의 세션 쿠키와 기타 인증 정보를 포함하는 위조된 HTTP 요청을 취약한 웹 어플리케이션에 전송하는 취약점
취약한 패스워드 복구	◆취약한 패스워드 복구 메커니즘(패스워드 찾기 등)에 대해 공격자가 불법적으로 다른 사용자의 패스워드를 획득, 변경, 복구할 수 있는 취약점

디렉터리 인덱싱	◆웹 서버에서 인덱스 파일로 지정한 파일이 존재하지 않거나, 웹 서버에 디렉터리리스팅을 허락하도록 설정했을 경우 디렉터리 리스트를 출력하는 취약점 ◆디렉터리 나열 점검 → 기본 페이지가 없는 URL 처리 여부 체크
SSI 인젝션	◆SSI(Server-side Include)는 “Last modified”와 같이 서버가 HTML 문서에 입력하는 변수 값으로, 웹 서버상에 있는 파일을 include 시키고, 명령문이 실행되게 하여 데이터에 접근할 수 있는 취약점
정보 노출	◆웹 사이트 데이터가 노출되는 것으로 개발과정의 코멘트나 오류 메시지 등에서 중요한 정보가 노출되어 공격자에게 2차 공격을 하기 위한 중요 정보를 제공할 수 있는 취약점 ◆시스템/애플리케이션 설치 시 기본 설정파일 점검 ◆개발 시 테스트를 하거나 백업 및 톨에 의해 생성되는 파일점검 ◆URL에 존재하지 않는 경로나 임의의 파일 요청 등 비정상적인 값에 대한 에러처리 점검 → 기본 페이지가 없는 URL 처리 여부 체크(Error 코드에 웹 어플리케이션의 종류 및 버전, 사용하는 DB 정보, 시스템 정보 노출 체크) ◆검색엔진에 노출된 콘텐츠 점검 → 검색엔진에 노출된 콘텐츠에 대한 중요 정보 노출확인 및 교차분석 가능 여지 파악
관리자 페이지 노출	◆단순한 관리자 페이지 이름(admin, manager 등)이나 설정, 프로그램 설계상의 오류로 인해 관리자 메뉴에 직접 접근할 수 있는 취약점 ◆관리자 페이지 노출/접근 가능성 점검 → 외부 사용자가 관리자 페이지로 접근가능 여부 확인
위치 공개	◆예측 가능한 디렉터리나 파일명을 사용하여 해당 위치가 쉽게 노출되어 공격자가 이를 악용하여 대상에 대한 정보와 민감한 정보가 담김 데이터에 접근이 가능하게 되는 취약점
세션 예측	◆단순히 숫자가 증가하는 방법 등의 취약한 특정 세션의 식별자(ID)를 예측하여 세션을 가로챌 수 있는 취약점
불충분한 인가	◆민감한 데이터 또는 기능에 대한 접근권한 제한을 두지 않은 취약점
세션 고정	◆세션 값을 고정하여 명확한 세션 식별자(ID) 값으로 사용자가 로그인하여 정의된 세션 식별자(ID)가 사용 가능하게 되는 취약점
불충분한 인증	◆민감한 데이터에 접근할 수 있는 곳에 취약한 인증 메커니즘으로 구현된 취약점
자동화 공격	◆웹 어플리케이션에 정해진 프로세스 자동화된 공격을 수행함으로써 자동으로 수 많은 프로세스가 진행되는 취약점
경로 추적	◆공격자에게 외부에서 디렉터리에 접근할 수 있는 것이 허가되는 문제점으로 웹 루트 디렉터리에서 외부의 파일까지 접근하고 실행할 수 있는 취약점

4. 보안준수사항

- 1) 취약점 점검 시 취약점 유무 확인단계까지 점검을 수행하며 민감한 사항의 열람, 삭제, 수정 실시하지 않음
- 2) 정보보호 컨설팅 서비스 수행 시 알거나 습득한 내용에 대해서는 외부 유출, 목적 외 이용을 안 함
 - 정보통신망법 제49조(비밀 등의 보호) 규정 등 준수

누구든지 정보통신망에 의하여 처리·보관 또는 전송되는 타인의 정보를 훼손하거나 타인의 비밀을 침해·도용 또는 누설하여서는 아니 된다.

- 정보통신망법 벌칙 제71조 제11항 규정에 따른 비밀보호 등 준수

다음 각 호의 어느 하나에 해당하는 자는 5년 이하의 징역 또는 5천만원 이하의 벌금에 처한다.

1. 제22조제1항(제67조에 따라 준용되는 경우를 포함한다)을 위반하여 이용자의 동의를 받지 아니하고 개인정보를 수집한 자
2. 제23조제1항(제67조에 따라 준용되는 경우를 포함한다)을 위반하여 이용자의 동의를 받지 아니하고 개인의 권리·이익이나 사생활을 뚜렷하게 침해할 우려가 있는 개인정보를 수집한 자
3. 제24조, 제24조의2제1항 및 제2항 또는 제26조제3항(제67조에 따라 준용되는 경우를 포함한다)을 위반하여 개인정보를 이용하거나 제3자에게 제공한 자 및 그 사정을 알면서도 영리 또는 부정한 목적으로 개인정보를 제공받은 자
4. 제25조제1항(제67조에 따라 준용되는 경우를 포함한다)을 위반하여 이용자의 동의를 받지 아니하고 개인정보 취급 위탁을 한 자
5. 제28조의2제1항(제67조에 따라 준용되는 경우를 포함한다)을 위반하여 이용자의 개인정보를 훼손·침해 또는 누설한 자
6. 제28조의2제2항을 위반하여 그 개인정보가 누설된 사정을 알면서도 영리 또는 부정한 목적으로 개인정보를 제공받은 자
7. 제30조제5항(제30조제7항, 제31조제3항 및 제67조에 따라 준용되는 경우를 포함한다)을 위반하여 필요한 조치를 하지 아니하고 개인정보를 제공하거나 이용한 자
8. 제31조제1항(제67조에 따라 준용되는 경우를 포함한다)을 위반하여 법정대리인의 동의를 받지 아니하고 만 14세 미만인 아동의 개인정보를 수집한 자
9. 제48조제2항을 위반하여 악성프로그램을 전달 또는 유포한 자
10. 제48조제3항을 위반하여 정보통신망에 장애가 발생하게 한 자
11. 제49조를 위반하여 타인의 정보를 훼손하거나 타인의 비밀을 침해·도용 또는 누설한 자